# CRISC Governance, Ethics and Analysis – 100 Real-Life Questions

## Governance, Ethics, Threats, Analysis and Exam Mindset – Practical Scenarios

CRISC Mastery Series

October 23, 2026

# Instructions

## How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

# Outline


1. Governance, Strategy and Culture
2. Three Lines, Appetite and Roles
3. Laws, Ethics and Professional Conduct
4. Threats, Vulnerabilities and Analysis
5. Assessment Methods, BIA and Analysis
6. Incidents, Issues and the Risk Lifecycle
7. Mixed Exam-Style Scenarios
8. Conclusion

# Q1: Governance vs Management

## Question

Which statement **BEST** distinguishes governance from management?

**(A)** They are the same function with different names

**(B)** Governance runs daily operations, and management sets strategy

**(C)** Governance sets direction and oversight, while management plans, builds, and runs activities to achieve it

**(D)** Governance applies only to IT, and management applies to finance

# Q1: Explanation

## Correct Answer: C

- The board and executives direct and oversee through governance.
- Management carries out the direction day to day.
- Confusing the two blurs accountability.

## Key Takeaway

Governance directs; management executes.

# Q2: Aligning Risk to Strategy

**Question**

The company adopts a strategy of rapid digital expansion. What should the risk practitioner do **FIRST**?

**(A)** Freeze all new technology projects

**(B)** Copy the risk register of a competitor

**(C)** Understand the strategic objectives and identify the risks that could affect them

**(D)** Increase the security budget by a fixed amount

# Q2: Explanation

## Correct Answer: C

- Risk is defined relative to objectives.
- Understanding strategy lets you focus on what matters.
- Blanket restrictions can block the strategy itself.

## Key Takeaway

Risk management supports objectives; it does not oppose them.

# Q3: Board Oversight

**Question**

What is the board's **PRIMARY** role in IT risk?

**(A)** Configure firewalls

**(B)** Approve every access request

**(C)** Perform vulnerability scans

**(D)** Provide oversight and ensure risk management aligns with strategy and appetite

# Q3: Explanation

## Correct Answer: D

- The board is accountable for governance.
- It sets or endorses risk appetite.
- Operational tasks belong to management and specialists.

## Key Takeaway

The board oversees; it does not operate.

# Q4: Risk Culture

## Question

Employees hide mistakes because they fear punishment. What is the **BEST** way to improve the risk culture?

**(A)** Add stricter penalties for every error

**(B)** Publish a longer policy

**(C)** Leaders model transparency and reward timely reporting of issues

**(D)** Limit reporting to managers only

# Q4: Explanation

## Correct Answer: C

- Culture follows what leaders do and reward.
- Fear suppresses reporting and increases hidden risk.
- Policies alone do not change behavior.

## Key Takeaway

People report risk where it is safe to do so.

# Q5: Policy Hierarchy

**Question**

Which describes the correct relationship among policies, standards, and procedures?

**(A)** Procedures set strategy, and policies list steps

**(B)** Standards replace policies

**(C)** They all contain the same content

**(D)** Policies state intent, standards set mandatory requirements, and procedures give step-by-step instructions

# Q5: Explanation

## Correct Answer: D

- Policies are high-level and approved by management.
- Standards specify measurable requirements.
- Procedures explain how to carry out tasks.

## Key Takeaway

Why, what, then how.

# Q6: Outdated Policy

## Question

A security policy has not been reviewed in six years and no longer matches the technology in use. What is the **BEST** action?

**(A)** Review and update it through the defined approval process, and communicate the changes

**(B)** Leave it because it was once approved

**(C)** Delete it

**(D)** Let each team write its own

# Q6: Explanation

## Correct Answer: A

- Policies must stay relevant to the environment.
- Approval gives them authority.
- Communication ensures awareness.

## Key Takeaway

A stale policy is a weak control.

# Q7: RACI Gap

**Question**

During an incident, two teams each assume the other is responsible for communication. Which tool would have **BEST** prevented this?

**(A)** A larger incident budget

**(B)** A RACI matrix defining who is responsible, accountable, consulted, and informed

**(C)** A new firewall

**(D)** A longer password policy

# Q7: Explanation

## Correct Answer: B

- RACI clarifies roles for each activity.
- Exactly one party should be accountable.
- Clear roles speed response.

## Key Takeaway

If everyone owns it, no one does.

# Q8: Asset Inventory First

## Question

A risk assessment is starting, but the asset inventory is incomplete. What is the **BEST** next step?

**(A)** Assess only the assets already known to IT

**(B)** Skip assets and list threats only

**(C)** Identify and prioritize critical assets with their owners before assessing risk

**(D)** Assess every device at equal depth

# Q8: Explanation

## Correct Answer: C

- You cannot assess risk to assets you do not know.
- Prioritization focuses effort on business value.
- Owners provide value and impact information.

## Key Takeaway

No inventory, no meaningful assessment.

# Q9: Asset Valuation

## Question

Which factor is **MOST** important when valuing an information asset?

**(A)** Its importance to business processes and the impact if it were lost, altered, or disclosed

**(B)** The purchase price of the hardware

**(C)** The age of the server

**(D)** The brand of the software

# Q9: Explanation

## Correct Answer: A

- Information value depends on business use.
- Replacement cost can be much lower than impact.
- Value drives the level of protection.

## Key Takeaway

Value the impact, not the invoice.

# Q10: Risk Strategy

## Question

Which of these **BEST** describes an IT risk strategy?

**(A)** A list of all software licenses

**(B)** A plan, aligned with business objectives, for how the organization will identify, assess, respond to, and monitor IT risk

**(C)** A schedule of penetration tests

**(D)** A report of last year's incidents

# Q10: Explanation

## Correct Answer: B

- Strategy sets the overall approach to risk.
- It supports business objectives.
- Lists and reports are inputs, not strategy.

## Key Takeaway

Strategy answers how risk will be managed, and why.

# Q11: IT Governance Frameworks

## Question

The organization wants a framework to align IT with business goals and manage IT governance. Which is the **BEST** fit?

**(A)** A network cabling standard

**(B)** A project scheduling tool

**(C)** A spreadsheet template

**(D)** COBIT

# Q11: Explanation

## Correct Answer: D

- COBIT focuses on governance and management of enterprise IT.
- It links business goals to IT goals.
- Frameworks should be adapted to the organization.

## Key Takeaway

COBIT governs IT; do not confuse it with tools.

# Q12: Cybersecurity Framework Use

## Question

A company wants a common language for describing its cybersecurity activities from identification to recovery. Which framework is **MOST** suitable?

**(A)** A software license agreement

**(B)** A coding style guide

**(C)** A procurement catalog

**(D)** NIST Cybersecurity Framework

# Q12: Explanation

## Correct Answer: D

- The NIST CSF organizes activities into functions.
- It helps communicate across technical and business teams.
- It supports maturity assessment.

## Key Takeaway

Use a framework to speak one language.

# Q13: IT Service Management

## Question

Which framework is **MOST** associated with IT service management practices such as incident and change management?

**(A)** ITIL

**(B)** The CRISC code of ethics

**(C)** A firewall rule base

**(D)** A data classification scheme

# Q13: Explanation

## Correct Answer: A

- ITIL describes service management processes.
- COBIT governs; ITIL manages services.
- They can be used together.

## Key Takeaway

COBIT governs, ITIL runs the services.

# Q14: Risk Practitioner Role

**Question**

What is the risk practitioner's **PRIMARY** role in governance?

**(A)** Make all risk decisions for the business

**(B)** Provide independent, objective risk information so decision makers can make informed choices

**(C)** Approve all projects

**(D)** Operate the controls

# Q14: Explanation

## Correct Answer: B

- Owners make decisions; practitioners inform them.
- Practitioners help identify, assess, and report risk.
- Operating controls creates conflicts of interest.

## Key Takeaway

Advise and inform; do not decide for the owner.

# Q15: Competing Priorities

## Question

Two departments demand opposite risk responses for a shared system. What should the risk practitioner do?

**(A)** Pick the department that complained first

**(B)** Implement both responses at once

**(C)** Delay the decision indefinitely

**(D)** Present the risk, business impact, and options to the accountable executive or governance body for decision

# Q15: Explanation

## Correct Answer: D

- Conflicts need an accountable decision maker.
- Clear impact information supports a fair choice.
- Delay leaves the risk open.

## Key Takeaway

Escalate conflicts with facts, not opinions.

# Q16: Ethical Culture Link

**Question**

How are ethics and risk culture related?

**(A)** They are unrelated

**(B)** Ethics matters only for external auditors

**(C)** Culture changes only through technology

**(D)** An ethical culture encourages honest reporting, whereas an unethical one hides or manipulates risk information

# Q16: Explanation

## Correct Answer: D

- Behavior at the top influences behavior throughout.
- Honest reporting depends on trust.
- Ethical lapses can create hidden risk.

## Key Takeaway

Ethics shapes what gets reported.

# Q17: First Line of Defense

## Question

Who forms the first line of defense in the three lines model?

**(A)** Internal audit

**(B)** Business and operational management who own and manage risks and controls

**(C)** The board's audit committee

**(D)** External regulators

# Q17: Explanation

## Correct Answer: B

- The first line owns risk in daily operations.
- The second line oversees and supports.
- The third line provides independent assurance.

## Key Takeaway

First line owns the risk.

# Q18: Second Line

**Question**

Which function is a typical second line of defense?

**(A)** Internal audit

**(B)** Risk management and compliance functions that oversee and challenge the first line

**(C)** The sales team

**(D)** External auditors

# Q18: Explanation

## Correct Answer: B

- The second line sets frameworks and monitors.
- It advises but does not own the operations.
- Independent assurance belongs to the third line.

## Key Takeaway

Second line oversees and challenges.

# Q19: Third Line

**Question**

What is the role of internal audit in the three lines model?

**(A)** Operate preventive controls

**(B)** Own and accept business risks

**(C)** Design the risk appetite

**(D)** Provide independent assurance on governance, risk management, and control effectiveness to the board

# Q19: Explanation

## Correct Answer: D

- Independence is essential to assurance.
- Audit reports to the board or audit committee.
- Operating controls would compromise objectivity.

## Key Takeaway

Third line assures; it does not operate.

# Q20: Independence Concern

## Question

Internal audit is asked to implement a new control and then audit it. What is the **MAIN** concern?

**(A)** Higher cost

**(B)** Slower deployment

**(C)** Fewer tools

**(D)** Loss of independence and objectivity

# Q20: Explanation

## Correct Answer: D

- Auditing your own work creates a conflict.
- Independence supports credible assurance.
- Management should implement controls.

## Key Takeaway

Do not audit what you built.

# Q21: Risk Appetite Basics

## Question

Which statement about risk appetite is **MOST** accurate?

**(A)** It is the amount and type of risk the organization is willing to pursue to achieve its objectives

**(B)** It is the maximum risk the organization can survive

**(C)** It is the risk remaining after controls

**(D)** It is the cost of insurance

# Q21: Explanation

## Correct Answer: A

- Appetite is a strategic choice set by leadership.
- Capacity is the maximum survivable level.
- Residual risk is measured after controls.

## Key Takeaway

Appetite is willingness; capacity is ability.

# Q22: Tolerance vs Appetite

## Question

Which describes risk tolerance?

**(A)** The acceptable deviation from appetite for specific objectives, often expressed as thresholds

**(B)** The amount of insurance purchased

**(C)** The number of controls in place

**(D)** The average vulnerability age

# Q22: Explanation

## Correct Answer: A

- Tolerance translates appetite into measurable limits.
- It is specific to objectives or risk types.
- KRIs often track tolerance thresholds.

## Key Takeaway

Tolerance puts numbers on appetite.

# Q23: Risk Capacity

**Question**

What does risk capacity represent?

**(A)** The risk that management prefers

**(B)** The risk after mitigation

**(C)** The risk transferred to insurers

**(D)** The maximum risk the organization can bear before its viability is threatened

# Q23: Explanation

## Correct Answer: D

- Capacity is a limit, not a preference.
- Appetite should be set below capacity.
- Exceeding capacity threatens survival.

## Key Takeaway

Never set appetite above capacity.

# Q24: Risk Profile

## Question

What is a risk profile?

**(A)** A single risk's remediation plan

**(B)** A description of the organization's identified risks and their levels at a point in time

**(C)** A staff performance review

**(D)** A vendor's marketing profile

# Q24: Explanation

## Correct Answer: B

- The profile summarizes risk exposure.
- It is compared against appetite and tolerance.
- It changes as risks and controls change.

## Key Takeaway

The risk profile is the current picture of exposure.

# Q25: Acceptance Documentation

## Question

A risk owner verbally agrees to accept a high risk. What should the risk practitioner do?

**(A)** Rely on the verbal agreement

**(B)** Ask audit to sign instead

**(C)** Ensure the acceptance is formally documented and approved at the appropriate authority level

**(D)** Mark the risk closed

# Q25: Explanation

## Correct Answer: C

- Accepted risk needs a record for accountability.
- Authority levels should match the risk level.
- Closed means resolved, not accepted.

## Key Takeaway

If it is not written down, it was not accepted.

# Q26: Accepting Beyond Authority

## Question

A department manager wants to accept a risk that exceeds their authority limit. What should happen?

**(A)** Let the manager accept it anyway

**(B)** Reduce the rating to fit the limit

**(C)** Escalate to the level of management that has authority for that level of risk

**(D)** Ignore the request

# Q26: Explanation

## Correct Answer: C

- Authority limits reflect governance decisions.
- Adjusting ratings to fit limits is manipulation.
- Escalation maintains accountability.

## Key Takeaway

Risk acceptance must go to the right level.

# Q27: Risk Practitioner vs Owner

## Question

Who is typically accountable for the day-to-day management of a specific risk?

**(A)** The risk practitioner

**(B)** The external auditor

**(C)** The vendor

**(D)** The risk owner

# Q27: Explanation

## Correct Answer: D

- Owners have authority over the related process and resources.
- Practitioners provide guidance and challenge.
- Accountability cannot be delegated outward.

## Key Takeaway

Risk owner = accountable.

# Q28: Control Owner vs Risk Owner

## Question

Which statement correctly differentiates a control owner from a risk owner?

**(A)** The control owner operates a control, and the risk owner is accountable for the risk the control addresses

**(B)** They are always the same person

**(C)** The control owner accepts all risk

**(D)** The risk owner operates all controls

# Q28: Explanation

## Correct Answer: A

- Control owners perform and evidence controls.
- Risk owners decide on response and acceptance.
- Roles can overlap but responsibilities differ.

## Key Takeaway

One runs the control, one owns the risk.

# Q29: Appetite Cascades

## Question

Different departments define their own conflicting risk appetites. What is the **BEST** approach?

**(A)** Let each department set its own without review

**(B)** Use the most conservative one only

**(C)** Remove appetite statements

**(D)** Align them to an enterprise-level appetite approved by leadership and cascade it consistently

# Q29: Explanation

## Correct Answer: D

- Enterprise appetite ensures consistency.
- Departments set tolerances within it.
- Conflicts weaken decisions and reporting.

## Key Takeaway

One enterprise appetite, many aligned tolerances.

# Q30: Escalating Cyber Risk

## Question

Which cybersecurity issue is **MOST** appropriate for escalation to the board?

**(A)** A risk exceeding the approved appetite that threatens strategic objectives

**(B)** A single low-severity virus alert

**(C)** A routine patch schedule

**(D)** A minor printer outage

# Q30: Explanation

## Correct Answer: A

- Boards need strategic, material information.
- Low-level events are handled operationally.
- Escalation criteria should be defined.

## Key Takeaway

Escalate what is material, not what is merely noisy.

# Q31: Applicable Regulations

## Question

The company expands into a new region. What should the risk practitioner do **FIRST** regarding legal requirements?

**(A)** Assume home-country laws apply everywhere

**(B)** Work with legal and compliance to identify applicable laws and their impact on processes and controls

**(C)** Wait for a regulator's letter

**(D)** Rely on a competitor's website

# Q31: Explanation

## Correct Answer: B

- Legal obligations vary by jurisdiction.
- Legal experts interpret the requirements.
- Early identification avoids costly rework.

## Key Takeaway

Know which laws apply before you operate.

# Q32: Compliance vs Risk

**Question**

A control meets a regulation, but a risk assessment still shows high exposure. What does this indicate?

**(A)** Compliance always means no risk

**(B)** Compliance does not guarantee acceptable risk, so additional response may be needed

**(C)** The risk assessment is wrong

**(D)** The regulation is unnecessary

# Q32: Explanation

## Correct Answer: B

- Regulations set minimum requirements.
- Risk depends on the specific context.
- Both views are needed.

## Key Takeaway

Compliant is not the same as secure.

# Q33: Code of Ethics

## Question

A risk practitioner discovers that management is overstating control effectiveness in a report to the board. What should they do?

**(A)** Stay silent to protect the manager

**(B)** Leak the report externally at once

**(C)** Raise the concern through appropriate channels and ensure accurate information is reported, in line with professional ethics

**(D)** Change the report secretly to match what they believe

# Q33: Explanation

## Correct Answer: C

- Professional codes require honesty and integrity.
- Use proper escalation channels first.
- Unilateral or secret action can create further problems.

## Key Takeaway

Integrity first; escalate through proper channels.

# Q34: Conflict of Interest

## Question

A risk practitioner is asked to assess a vendor owned by a close relative. What is the **BEST** action?

**(A)** Do the assessment and say nothing

**(B)** Disclose the conflict and recuse themselves from the assessment

**(C)** Give the vendor a favorable rating

**(D)** Delay the project

# Q34: Explanation

## Correct Answer: B

- Undisclosed conflicts damage trust.
- Independence supports objective assessment.
- Disclosure lets management reassign the task.

## Key Takeaway

Disclose conflicts early.

# Q35: Confidentiality Duty

**Question**

A practitioner learns confidential information during an assessment. When may it be shared?

**(A)** With anyone interested in the topic

**(B)** On social media in general terms

**(C)** With a future employer

**(D)** Only with authorized parties, and as required by law or approved by the organization

# Q35: Explanation

## Correct Answer: D

- Professional ethics require protecting confidential information.
- Disclosure must be authorized or legally required.
- Sharing for personal gain is a violation.

## Key Takeaway

What you learn on the job stays on the job.

# Q36: Data Breach Law

**Question**

A breach involving personal data occurs. What should the organization do regarding legal obligations?

**(A)** Wait until the investigation is fully complete

**(B)** Notify only if customers complain

**(C)** Avoid documenting the breach

**(D)** Determine notification duties and timelines with legal counsel and act within the required timeframe

# Q36: Explanation

## Correct Answer: D

- Laws may set strict notification deadlines.
- Legal counsel interprets requirements.
- Documentation supports compliance.

## Key Takeaway

Notification clocks start early; plan for them.

# Q37: Payment Card Standard

## Question

The company processes card payments. Which requirement set is **MOST** directly relevant?

**(A)** A software coding style guide

**(B)** The corporate dress code

**(C)** The Payment Card Industry Data Security Standard

**(D)** An office safety manual

# Q37: Explanation

## Correct Answer: C

- PCI DSS sets security requirements for card data.
- Compliance is often contractual.
- Scope reduction lowers cost and risk.

## Key Takeaway

Card data brings card rules.

# Q38: Health Data Rules

## Question

A software provider will handle patient health records for US healthcare organizations. Which law is **MOST** relevant?

**(A)** The Health Insurance Portability and Accountability Act (HIPAA)

**(B)** The Sarbanes-Oxley Act only

**(C)** A local building code

**(D)** The Fair Credit Reporting Act only

# Q38: Explanation

## Correct Answer: A

- HIPAA protects health information.
- Business associates have obligations too.
- Contracts should define responsibilities.

## Key Takeaway

Match the data type to its governing law.

# Q39: Financial Reporting Controls

## Question

A public company must show effective controls over financial reporting. Which law is **MOST** associated with this requirement?

**(A)** The Health Insurance Portability and Accountability Act

**(B)** The Sarbanes-Oxley Act

**(C)** The Children's Online Privacy Protection Act

**(D)** The Telephone Consumer Protection Act

# Q39: Explanation

## Correct Answer: B

- SOX focuses on financial reporting and internal controls.
- IT general controls support those reports.
- Executives certify the controls.

## Key Takeaway

SOX equals financial reporting controls.

# Q40: Privacy Regulation Scope

## Question

A non-EU company offers services to individuals in the EU and processes their personal data. What is true?

**(A)** It never applies outside the EU

**(B)** It applies only to EU-based companies

**(C)** It applies only to government agencies

**(D)** The EU General Data Protection Regulation may apply because of the targeting of EU residents

# Q40: Explanation

## Correct Answer: D

- GDPR has extraterritorial reach.
- Targeting or monitoring EU individuals triggers it.
- Penalties can be significant.

## Key Takeaway

Where your customers are matters as much as where you are.

# Q41: Speaking Up

## Question

A colleague asks the practitioner to downgrade a risk rating because the project will otherwise be delayed. What should the practitioner do?

**(A)** Lower the rating to help the project

**(B)** Decline, explain the basis for the rating, and escalate if pressure continues

**(C)** Delete the risk from the register

**(D)** Ignore the colleague silently

# Q41: Explanation

## Correct Answer: B

- Ratings must reflect evidence, not convenience.
- Transparency protects the organization.
- Escalation handles undue pressure.

## Key Takeaway

Ratings follow facts, not deadlines.

# Q42: Professional Competence

## Question

A practitioner is asked to assess a technology they do not understand. What is the **BEST** approach?

**(A)** Give a confident opinion anyway

**(B)** Refuse all future assessments

**(C)** Acknowledge the limitation and obtain expert support or training before giving conclusions

**(D)** Copy another company's rating

# Q42: Explanation

## Correct Answer: C

- Ethics require competence and honesty.
- Expert input improves accuracy.
- Overstating knowledge creates risk.

## Key Takeaway

Know what you do not know.

# Q43: Threat vs Vulnerability

## Question

Which statement correctly relates threat, vulnerability, and risk?

**(A)** A vulnerability is the same as a threat

**(B)** Risk arises when a threat can exploit a vulnerability to cause impact on an asset

**(C)** Risk exists without any vulnerability or threat

**(D)** Threats are always internal

# Q43: Explanation

## Correct Answer: B

- Threats are potential causes of harm.
- Vulnerabilities are weaknesses that can be exploited.
- Risk combines likelihood and impact.

## Key Takeaway

No exploitable weakness and no threat means no risk.

# Q44: Threat Modeling Purpose

## Question

What is the primary purpose of threat modeling?

**(A)** Identify how a system could be attacked and prioritize defenses early in design

**(B)** Replace vulnerability scanning

**(C)** Document staff vacation plans

**(D)** Measure network bandwidth

# Q44: Explanation

## Correct Answer: A

- It structures thinking about attackers and assets.
- Early use improves design.
- It complements, not replaces, testing.

## Key Takeaway

Think like the attacker before it ships.

# Q45: STRIDE

## Question

A team categorizes threats as spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege. Which method is this?

**(A)** SWOT

**(B)** PERT

**(C)** RACI

**(D)** STRIDE

# Q45: Explanation

## Correct Answer: D

- STRIDE is a threat categorization model.
- It helps systematically find threats.
- Other methods include attack trees and PASTA.

## Key Takeaway

STRIDE lists the six threat types.

# Q46: Vulnerability Scanning Limits

## Question

A scan reports no critical vulnerabilities. What is the **MOST** accurate conclusion?

**(A)** The system is completely secure

**(B)** No attacker can succeed

**(C)** Known vulnerabilities within the scan scope were not found, but other weaknesses may still exist

**(D)** No more testing is ever needed

# Q46: Explanation

## Correct Answer: C

- Scans detect known issues in scope.
- Logic flaws and misconfigurations can be missed.
- Combine scans with other assessments.

## Key Takeaway

A clean scan is not a clean bill of health.

# Q47: Penetration Test Value

## Question

Why conduct a penetration test in addition to vulnerability scanning?

**(A)** To avoid fixing vulnerabilities

**(B)** To replace risk assessments

**(C)** To test employee punctuality

**(D)** To attempt to exploit weaknesses and show realistic attack impact

# Q47: Explanation

## Correct Answer: D

- Pen tests demonstrate real exploitability.
- They can chain issues like an attacker.
- Results still need risk-based prioritization.

## Key Takeaway

Scanning finds; testing proves.

# Q48: Patch Prioritization

## Question

Hundreds of vulnerabilities are open and patching capacity is limited. How should they be prioritized?

**(A)** By severity, exploitability, asset criticality, and exposure

**(B)** By alphabetical order of the system name

**(C)** By the order discovered

**(D)** By how easy they are to describe

# Q48: Explanation

## Correct Answer: A

- Risk-based prioritization focuses on real exposure.
- Active exploitation raises urgency.
- Critical and exposed assets come first.

## Key Takeaway

Patch by risk, not by list order.

# Q49: Zero-Day

## Question

A newly disclosed vulnerability has no patch yet and is being actively exploited. What is the **BEST** immediate response?

**(A)** Wait quietly for a patch

**(B)** Apply compensating controls such as isolation, filtering, or monitoring, and track vendor guidance

**(C)** Ignore it until the next audit

**(D)** Shut down the whole company permanently

# Q49: Explanation

## Correct Answer: B

- Compensating controls reduce exposure.
- Monitoring detects exploitation attempts.
- A decision on temporary shutdown depends on impact.

## Key Takeaway

No patch? Compensate.

# Q50: Insider Threat

**Question**

Which control **BEST** reduces the risk of malicious insider data theft?

**(A)** Longer lunch breaks

**(B)** Posters about loyalty only

**(C)** Removing all logging

**(D)** Least privilege, activity monitoring, and data loss prevention

# Q50: Explanation

## Correct Answer: D

- Limiting access limits possible damage.
- Monitoring deters and detects misuse.
- Technical and procedural controls work together.

## Key Takeaway

Trust, but limit and monitor.

# Q51: Social Engineering

## Question

An attacker phones the help desk pretending to be an executive and asks for a password reset. What is the **BEST** defense?

**(A)** More firewalls

**(B)** Strict identity verification procedures and staff training

**(C)** Longer passwords only

**(D)** Faster ticket closure

# Q51: Explanation

## Correct Answer: B

- The attack targets people, not technology.
- Verification steps prevent impersonation.
- Training builds awareness.

## Key Takeaway

Humans are part of the control environment.

# Q52: Supply Chain Attack

## Question

A trusted software vendor's update contains malicious code. Which control **BEST** reduces this risk?

**(A)** Install updates on all systems instantly without review

**(B)** Stop applying all updates

**(C)** Validate update integrity, apply staged deployment, and monitor behavior after updates

**(D)** Trust all signed updates unconditionally

# Q52: Explanation

## Correct Answer: C

- Supply chain attacks abuse trust.
- Staging limits blast radius.
- Monitoring detects unexpected behavior.

## Key Takeaway

Trust, then verify, even for vendors.

# Q53: Ransomware Resilience

## Question

Which measure is **MOST** effective at reducing the impact of ransomware?

**(A)** Tested, offline or immutable backups combined with prevention and detection controls

**(B)** Paying the ransom as the main plan

**(C)** Storing backups on the same network share

**(D)** Relying on cyber insurance alone

# Q53: Explanation

## Correct Answer: A

- Backups enable recovery without paying.
- Offline or immutable copies resist encryption.
- Prevention reduces the chance of infection.

## Key Takeaway

Recoverability beats negotiation.

# Q54: Denial of Service

## Question

An online store fears downtime from large traffic floods. Which control is **MOST** relevant?

**(A)** Stronger passwords

**(B)** Encrypting backups

**(C)** DDoS protection services and capacity planning

**(D)** Disk quotas

# Q54: Explanation

## Correct Answer: C

- DoS threatens availability.
- Mitigation services absorb or filter traffic.
- Response plans define actions.

## Key Takeaway

Match the control to the threat's target.

# Q55: Risk Scenarios

## Question

Why are risk scenarios useful in risk assessment?

**(A)** They replace the need for data

**(B)** They describe how a threat could exploit a weakness to cause business impact, making risk understandable

**(C)** They are used only for audits

**(D)** They eliminate the need for owners

# Q55: Explanation

## Correct Answer: B

- Scenarios link cause, event, and consequence.
- They help stakeholders discuss realistic risks.
- They support likelihood and impact estimates.

## Key Takeaway

Tell the risk as a story with consequences.

# Q56: Threat Intelligence

## Question

How does threat intelligence **BEST** support risk assessment?

**(A)** By replacing internal monitoring

**(B)** By guaranteeing prevention

**(C)** By providing current information on actors, techniques, and trends relevant to the organization

**(D)** By lowering all risk ratings

# Q56: Explanation

## Correct Answer: C

- It informs likelihood estimates.
- Relevance to the sector and technology matters.
- It supports proactive control updates.

## Key Takeaway

Intelligence informs likelihood.

# Q57: Attack Surface

## Question

What is the **BEST** way to reduce an organization's attack surface?

**(A)** Add more internet-facing services

**(B)** Remove unnecessary systems, services, and access that are not needed for the business

**(C)** Keep old accounts active

**(D)** Disable patching

# Q57: Explanation

## Correct Answer: B

- Fewer exposed components mean fewer opportunities.
- Unused assets add risk without benefit.
- Inventory is needed to find them.

## Key Takeaway

What is not there cannot be attacked.

# Q58: Vulnerability Management Program

## Question

Which element is essential to a mature vulnerability management program?

**(A)** A single annual scan

**(B)** A repeatable cycle of discovery, prioritization, remediation, verification, and reporting

**(C)** A list with no owners

**(D)** Fixing only what auditors mention

# Q58: Explanation

## Correct Answer: B

- Vulnerabilities appear continually.
- Verification confirms the fix worked.
- Reporting supports accountability.

## Key Takeaway

Vulnerability management is a cycle, not an event.

# Q59: Qualitative vs Quantitative

## Question

The organization has little historical loss data and needs a quick, consistent view of many risks. Which approach is **MOST** appropriate?

**(A)** Quantitative modeling with precise dollar values for all risks

**(B)** No assessment until data exists

**(C)** Qualitative assessment using defined rating scales

**(D)** Random scoring

# Q59: Explanation

## Correct Answer: C

- Qualitative methods work with limited data.
- Defined scales improve consistency.
- Quantitative analysis may follow for key risks.

## Key Takeaway

Use the method the available data supports.

# Q60: Quantitative Strength

## Question

When is a quantitative risk assessment **MOST** valuable?

**(A)** When financial justification is needed to compare options for high-impact risks and reliable data is available

**(B)** When there is no data at all

**(C)** For every low-level risk

**(D)** When the audience dislikes numbers

# Q60: Explanation

## Correct Answer: A

- Dollar values support cost-benefit decisions.
- Quality of results depends on data quality.
- Use for material risks where effort is justified.

## Key Takeaway

Numbers help when you can trust the inputs.

# Q61: Annualized Loss

## Question

A single loss event is estimated at 200,000 dollars and is expected to occur once every four years. What is the annualized loss expectancy?

**(A)** 50,000 dollars

**(B)** 200,000 dollars

**(C)** 800,000 dollars

**(D)** 4,000 dollars

# Q61: Explanation

## Correct Answer: A

- ALE equals single loss expectancy times annual rate of occurrence.
- Once every four years means a rate of 0.25 per year.
- 200,000 multiplied by 0.25 equals 50,000.

## Key Takeaway

ALE = SLE times ARO.

# Q62: Control Cost Decision

## Question

A control costs 80,000 dollars per year and reduces expected annual loss from 120,000 to 70,000 dollars. What is the **BEST** conclusion?

**(A)** It is justified because loss is reduced

**(B)** It is justified because 120,000 is greater than 80,000

**(C)** The control is not cost-justified based on loss reduction alone, since it saves 50,000 for an 80,000 cost

**(D)** Cost is irrelevant to risk decisions

# Q62: Explanation

## Correct Answer: C

- Compare reduction in expected loss to control cost.
- Non-financial factors may still apply, such as regulation.
- Decisions should be documented.

## Key Takeaway

Benefit must exceed cost, unless law or ethics say otherwise.

# Q63: Likelihood Inputs

## Question

Which sources **BEST** support a likelihood estimate for a risk scenario?

**(A)** Only the opinion of the loudest manager

**(B)** Incident history, threat intelligence, control effectiveness, and expert judgment

**(C)** A coin flip

**(D)** Marketing material

# Q63: Explanation

## Correct Answer: B

- Multiple sources improve reliability.
- Control strength affects likelihood.
- Document assumptions.

## Key Takeaway

Estimate with evidence, not volume.

# Q64: Business Impact Analysis Purpose

## Question

What is the main purpose of a business impact analysis?

**(A)** To rate employees

**(B)** To identify critical processes and the impact of their disruption over time

**(C)** To test network speed

**(D)** To choose office furniture

# Q64: Explanation

## Correct Answer: B

- BIA determines criticality and recovery priorities.
- It informs RTO and RPO.
- It uses business input, not only IT.

## Key Takeaway

BIA tells you what must come back first.

# Q65: BIA vs Risk Assessment

**Question**

How does a BIA differ from a risk assessment?

**(A)** They are identical

**(B)** A BIA considers only likelihood

**(C)** A BIA focuses on the impact of disruption to processes, while a risk assessment considers threats, vulnerabilities, likelihood, and impact

**(D)** A risk assessment ignores impact

# Q65: Explanation

## Correct Answer: C

- BIA is impact-centered and process-focused.
- Risk assessment adds likelihood and causes.
- The two inform each other.

## Key Takeaway

BIA asks what hurts; risk assessment asks how likely.

# Q66: Maximum Tolerable Downtime

## Question

The BIA shows that if a process is down more than 8 hours, the business faces severe consequences. What does this value represent?

**(A)** Maximum tolerable downtime

**(B)** Recovery point objective

**(C)** Risk tolerance for phishing

**(D)** Mean time between failures

# Q66: Explanation

## Correct Answer: A

- MTD is the longest acceptable outage.
- RTO must be shorter than MTD.
- Dependencies must also be recoverable in time.

## Key Takeaway

RTO must fit inside MTD.

# Q67: Inherent Risk

## Question

Which term describes risk before any controls or responses are considered?

**(A)** Residual risk

**(B)** Target risk only

**(C)** Inherent risk

**(D)** Accepted risk

# Q67: Explanation

## Correct Answer: C

- Inherent risk is the raw exposure.
- Controls reduce it to residual risk.
- Comparing both shows control value.

## Key Takeaway

Inherent minus controls equals residual.

# Q68: Risk Register Quality

**Question**

Which risk register entry is **BEST** written?

**(A)** Unpatched internet-facing server could be exploited, causing data loss and 2 days of outage; owner: operations director

**(B)** Server issue

**(C)** Bad things might happen

**(D)** Fix patches

# Q68: Explanation

## Correct Answer: A

- A clear risk statement links cause, event, and impact.
- An owner is named.
- Vague entries cannot be managed.

## Key Takeaway

Write the risk so a decision maker can act on it.

# Q69: Risk Scoring Consistency

## Question

Different assessors rate the same risk very differently. What is the **BEST** fix?

**(A)** Define and train on common rating criteria, then calibrate results across assessors

**(B)** Average randomly

**(C)** Use the highest rating always

**(D)** Let each business unit invent its own scale

# Q69: Explanation

## Correct Answer: A

- Shared scales produce comparable results.
- Calibration reduces bias.
- Consistency supports aggregation.

## Key Takeaway

Calibrate the ruler before you measure.

# Q70: Heat Map Limits

**Question**

What is a limitation of relying only on a heat map to report risk?

**(A)** It uses colors

**(B)** It can oversimplify and hide assumptions, so it should be supported with context and scenario detail

**(C)** It is always inaccurate

**(D)** It cannot be printed

# Q70: Explanation

## Correct Answer: B

- Heat maps summarize but lose nuance.
- Boundary values can mislead.
- Narrative explains drivers and actions.

## Key Takeaway

Pictures need explanations.

# Q71: Risk Aggregation

## Question

Many small risks are assessed in different departments. What is a benefit of aggregating them?

**(A)** It hides risk owners

**(B)** It reduces the number of controls needed

**(C)** It reveals combined exposure and common causes that individual assessments may miss

**(D)** It removes the need for appetite

# Q71: Explanation

## Correct Answer: C

- Related risks can compound.
- Common causes suggest shared responses.
- Aggregation supports enterprise reporting.

## Key Takeaway

Small risks can add up to a big one.

# Q72: Using Assessment Results

## Question

A risk assessment is complete. What should happen next?

**(A)** File the report and take no action

**(B)** Delete the underlying data

**(C)** Wait one year before sharing

**(D)** Communicate results to risk owners and decision makers and agree on responses

# Q72: Explanation

## Correct Answer: D

- Assessments exist to support decisions.
- Owners decide on response.
- Timely communication keeps results relevant.

## Key Takeaway

An assessment nobody acts on has no value.

# Q73: Reassessment Triggers

## Question

Which event is **MOST** likely to require a risk reassessment?

**(A)** A new office plant

**(B)** A holiday party

**(C)** A change in parking rules

**(D)** A significant change to a critical system or business process

# Q73: Explanation

## Correct Answer: D

- Change alters threats, vulnerabilities, and controls.
- Reassess promptly when conditions change.
- Waiting for the annual cycle may miss new risk.

## Key Takeaway

Change triggers reassessment.

# Q74: Risk Velocity

## Question

A risk could materialize within hours of a trigger, leaving very little time to respond. Which risk attribute does this describe?

**(A)** Residual risk

**(B)** Risk appetite

**(C)** Velocity, meaning the speed at which the risk event unfolds

**(D)** Inherent cost

# Q74: Explanation

## Correct Answer: C

- Fast-moving risks need pre-planned responses.
- Velocity complements likelihood and impact.
- Monitoring and automation help shorten reaction time.

## Key Takeaway

The faster the risk, the earlier you must prepare.

# Q75: Event vs Incident

## Question

Which statement **BEST** distinguishes an event from an incident?

**(A)** They mean the same thing

**(B)** An incident is harmless

**(C)** An event is any observable occurrence, while an incident is an event that causes or could cause harm or disruption

**(D)** An event always means a breach

# Q75: Explanation

## Correct Answer: C

- Many events are routine.
- Incidents require response.
- Breaches are incidents with confirmed unauthorized access.

## Key Takeaway

Events happen constantly; incidents hurt.

# Q76: First Incident Priority

## Question

A serious incident is confirmed. What should be the **FIRST** priority?

**(A)** Find someone to blame

**(B)** Rebuild all systems immediately without analysis

**(C)** Issue a press release before facts are known

**(D)** Contain the incident to limit damage while preserving evidence

# Q76: Explanation

## Correct Answer: D

- Containment stops the spread.
- Evidence supports investigation and legal needs.
- Recovery follows containment.

## Key Takeaway

Contain, then investigate, then recover.

# Q77: Incident Response Plan

## Question

What is the **MOST** important attribute of an effective incident response plan?

**(A)** A very long document

**(B)** Defined roles, escalation paths, and procedures that have been tested

**(C)** Secrecy from staff

**(D)** Use only by IT

# Q77: Explanation

## Correct Answer: B

- Clear roles prevent confusion.
- Testing reveals gaps.
- Plans should involve business and legal.

## Key Takeaway

A plan untested is a plan unproven.

# Q78: Lessons Learned Timing

**Question**

When should a lessons-learned review be held after an incident?

**(A)** Never

**(B)** Soon after recovery, while details are fresh, with findings fed into the risk register

**(C)** After one year

**(D)** Only if there was a fine

# Q78: Explanation

## Correct Answer: B

- Fresh recall improves quality.
- Findings drive improvement.
- Update scenarios and controls.

## Key Takeaway

Learn while the incident is still vivid.

# Q79: Issue Management

## Question

An audit identifies a control weakness. How should it be handled in the risk process?

**(A)** Ignore it until the next audit

**(B)** Close it without action

**(C)** Share it only with auditors

**(D)** Record it as an issue, assess its risk, assign an owner, and track the response to closure

# Q79: Explanation

## Correct Answer: D

- Issues are inputs to risk assessment.
- Owners and deadlines enable follow-up.
- Track until verified closed.

## Key Takeaway

Every issue needs an owner and an end date.

# Q80: Anomaly Response

## Question

A monitoring system shows unusual outbound traffic at night. What should be done **FIRST**?

**(A)** Dismiss it as noise

**(B)** Disconnect the entire company

**(C)** Investigate to determine whether it is a true incident, following the response procedure

**(D)** Wait for a customer complaint

# Q80: Explanation

## Correct Answer: C

- Triage determines severity.
- Procedures guide proportionate response.
- Ignoring anomalies can allow breaches to grow.

## Key Takeaway

Investigate before you panic or dismiss.

# Q81: Risk Management Lifecycle

## Question

Which sequence **BEST** reflects the IT risk management lifecycle?

**(A)** Report, ignore, forget, repeat

**(B)** Assess once and file

**(C)** Respond, then identify

**(D)** Identify, assess, respond, monitor, and report, repeating continuously

# Q81: Explanation

## Correct Answer: D

- Risk management is iterative.
- Monitoring feeds new identification.
- Reporting supports governance.

## Key Takeaway

The cycle never ends.

# Q82: Near Miss

## Question

A phishing email almost led to credential theft but was caught by an alert employee. What should be done?

**(A)** Ignore it because nothing was lost

**(B)** Punish the employee who received it

**(C)** Keep it secret

**(D)** Treat it as a near miss, learn from it, and update controls and awareness

# Q82: Explanation

## Correct Answer: D

- Near misses reveal weaknesses cheaply.
- Recognize good reporting behavior.
- Update indicators and training.

## Key Takeaway

Near misses are free lessons.

# Q83: Third-Party Incident Ownership

## Question

Your outsourced service provider suffers an outage affecting your customers. Who is **ULTIMATELY** accountable to your customers?

**(A)** Your organization

**(B)** The service provider alone

**(C)** The customers

**(D)** No one

# Q83: Explanation

## Correct Answer: A

- Accountability to customers remains with you.
- Contracts can allocate cost but not accountability.
- Oversight must match criticality.

## Key Takeaway

Customers hold you accountable, not your vendor.

# Q84: Regulatory Reporting Incident

## Question

An incident may trigger regulatory reporting. What is the **BEST** practice?

**(A)** Pre-define legal review and reporting procedures so decisions are fast and accurate

**(B)** Decide after press coverage

**(C)** Avoid involving legal

**(D)** Let each employee decide

# Q84: Explanation

## Correct Answer: A

- Deadlines may be very short.
- Prepared playbooks reduce errors.
- Consistent messages protect the organization.

## Key Takeaway

Prepare the notification process before you need it.

# Q85: Root Cause

## Question

After repeated outages, the team fixes each symptom but they recur. What is the **BEST** next step?

**(A)** Add more staff to the help desk

**(B)** Perform root cause analysis and address the underlying cause

**(C)** Restart systems more often

**(D)** Accept outages as normal

# Q85: Explanation

## Correct Answer: B

- Symptoms are not causes.
- Root cause fixes prevent recurrence.
- Update the risk register with findings.

## Key Takeaway

Fix the cause, not the symptom.

# Q86: Risk Monitoring Ownership

## Question

Who should **PRIMARILY** monitor day-to-day performance of a risk response within a department?

**(A)** The risk owner and control owners, with oversight from the second line

**(B)** The external auditor only

**(C)** The board only

**(D)** No one

# Q86: Explanation

## Correct Answer: A

- First line operates and watches controls.
- Second line challenges and aggregates.
- Third line assures independently.

## Key Takeaway

Monitoring starts where the work happens.

# Q87: Best Next Step

## Question

A new cloud service is already live and used by finance, but was never assessed. What should the risk practitioner do **FIRST**?

**(A)** Understand what data and processes are involved and assess the risk with the business owner

**(B)** Shut it down immediately

**(C)** Ignore it because it is already live

**(D)** Report the finance team to HR

# Q87: Explanation

## Correct Answer: A

- Understand before acting.
- The owner provides business context.
- Blocking may be considered after assessment.

## Key Takeaway

Assess, then decide; do not react blindly.

# Q88: Most Important Factor

## Question

Which is the **MOST** important factor when determining a risk's priority?

**(A)** The technology involved

**(B)** How interesting the risk is

**(C)** The name of the person who found it

**(D)** The potential impact on business objectives

# Q88: Explanation

## Correct Answer: D

- Priority follows business impact.
- Technical detail supports but does not decide priority.
- Objectives define what matters.

## Key Takeaway

Business objectives set the priority.

# Q89: Stakeholder Disagreement

## Question

The business owner disagrees with the risk rating. What should the risk practitioner do?

**(A)** Change the rating immediately

**(B)** Refuse to discuss

**(C)** Review the assumptions and evidence together, revise if justified, and escalate unresolved disagreement

**(D)** Delete the risk

# Q89: Explanation

## Correct Answer: C

- Dialogue may reveal new information.
- Ratings change only with evidence.
- Unresolved disputes go to governance.

## Key Takeaway

Discuss the evidence, not the preference.

# Q90: Budget Cut

## Question

Management cuts the security budget. What is the risk practitioner's **BEST** action?

**(A)** Assess the impact on risk exposure and present it to decision makers

**(B)** Quietly accept the cut

**(C)** Resign

**(D)** Hide the impact

# Q90: Explanation

## Correct Answer: A

- Decision makers need to understand consequences.
- Impact is expressed in business terms.
- They may accept the risk knowingly.

## Key Takeaway

Show what the cut costs in risk.

# Q91: Audit Disagreement

## Question

An auditor rates a control as ineffective, but the control owner disagrees. What should happen?

**(A)** Ignore the audit

**(B)** Remove the control

**(C)** Review the evidence together and resolve factual differences, with risk assessed on the final finding

**(D)** Threaten the auditor

# Q91: Explanation

## Correct Answer: C

- Facts should be agreed first.
- Independence must be respected.
- Residual risk should be updated.

## Key Takeaway

Evidence settles disputes.

# Q92: Automation Risk

**Question**

A robotic process automation tool will handle payments. Which risk consideration is **MOST** important?

**(A)** The robot's color

**(B)** The number of staff that can be laid off

**(C)** Marketing claims

**(D)** Access controls, change control, monitoring, and clear ownership for the automated process

# Q92: Explanation

## Correct Answer: D

- Automation can scale errors quickly.
- Bots need identities and least privilege.
- Ownership and monitoring remain essential.

## Key Takeaway

Automation still needs controls and an owner.

# Q93: Merger Integration

## Question

After a merger, two networks will be connected. What should the risk practitioner recommend **FIRST**?

**(A)** Assess the risk posture of the acquired environment before connecting

**(B)** Connect immediately to save time

**(C)** Ignore the acquired controls

**(D)** Merge all accounts without review

# Q93: Explanation

## Correct Answer: A

- Unknown weaknesses can spread.
- Assessment informs integration plans.
- Segmentation can limit exposure.

## Key Takeaway

Do not connect what you have not assessed.

# Q94: Remote Work Shift

## Question

The company moves to permanent remote work. What should the risk practitioner do?

**(A)** Reassess risks, update policies and controls for home environments, and communicate changes

**(B)** Assume the previous risk profile still applies

**(C)** Prohibit all home networks

**(D)** Wait for incidents

# Q94: Explanation

## Correct Answer: A

- Work location changes threats and controls.
- Policies and training must adapt.
- Reassessment supports good decisions.

## Key Takeaway

New ways of working need new risk views.

# Q95: Metrics for Management

**Question**

A manager asks how the risk program is doing. Which information is **BEST**?

**(A)** The number of meetings held

**(B)** Total pages in the risk policy

**(C)** Trends in key risk indicators against appetite, progress on response plans, and notable changes

**(D)** The size of the risk team

# Q95: Explanation

## Correct Answer: C

- Outcome measures show progress.
- Comparison to appetite gives context.
- Activity counts do not show value.

## Key Takeaway

Report outcomes, not activity.

# Q96: Whistleblower Issue

## Question

An employee anonymously reports control override by a senior executive. What should be done?

**(A)** Escalate through governance channels such as the audit committee, preserving confidentiality and evidence

**(B)** Tell the executive who reported

**(C)** Ignore the report

**(D)** Delete the evidence

# Q96: Explanation

## Correct Answer: A

- Independent oversight is needed.
- Protect reporters from retaliation.
- Evidence must be preserved.

## Key Takeaway

Serious allegations go to independent oversight.

# Q97: Cost of Control

## Question

A proposed control is expensive and reduces a low risk slightly. What is the **BEST** recommendation?

**(A)** Implement it because security always comes first

**(B)** Reject it without explanation

**(C)** Consider alternative, lower-cost responses or accept the risk with owner approval

**(D)** Hide the decision

# Q97: Explanation

## Correct Answer: C

- Controls must be proportionate.
- Alternatives may meet the objective.
- Acceptance should be documented.

## Key Takeaway

Proportionality beats perfection.

# Q98: New Technology Adoption

**Question**

The business wants to adopt an emerging technology quickly. What should the risk practitioner do?

**(A)** Block it until it is mature

**(B)** Engage early to identify risks and recommend proportionate controls without blocking value

**(C)** Ignore it

**(D)** Approve without review

# Q98: Explanation

## Correct Answer: B

- Early engagement enables safe adoption.
- Controls should fit the risk.
- Risk practitioners enable the business.

## Key Takeaway

Enable the business safely.

# Q99: Ultimate Accountability

## Question

Which statement about accountability for risk is **MOST** accurate?

**(A)** It can be fully transferred to vendors

**(B)** Accountability for risk stays with the organization and its owners even when activities are outsourced

**(C)** It belongs to the risk practitioner alone

**(D)** It disappears after insurance

# Q99: Explanation

## Correct Answer: B

- Contracts transfer tasks, not accountability.
- Owners must oversee outsourced work.
- Insurance covers cost, not responsibility.

## Key Takeaway

You can delegate tasks, not accountability.

# Q100: Exam Mindset

## Question

On the exam, several answers seem technically correct. Which approach usually leads to the **BEST** answer?

**(A)** Choose the option that best aligns with business objectives, ownership, and a risk-based, proportionate approach

**(B)** Choose the most technical option

**(C)** Choose the most expensive option

**(D)** Choose the option that acts fastest regardless of context

# Q100: Explanation

## Correct Answer: A

- ISACA favors business alignment and risk-based decisions.
- Understand before acting.
- Owners decide; practitioners advise.

## Key Takeaway

Think like an advisor to the business, not a technician.

# Exam Mindset Summary

## Remember These Core Principles

- **Business First:** Risk is defined by its effect on business objectives.
- **Owners Decide:** Practitioners inform; owners accept, mitigate, transfer, or avoid.
- **Three Lines:** The first line owns risk, the second oversees, and the third gives independent assurance.
- **Ethics Matter:** Honesty, independence, and confidentiality underpin credible risk advice.
- **Evidence Over Opinion:** Use data, scenarios, and calibrated ratings.
- **Proportionality:** Controls should fit the risk and its cost.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

# Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.